

セキュリティ説明

要点(1 枚版)

前提 — リスクを直視する

エラーログには API キーや接続文字列が日常的に混入します。「**混入する前提**」で**システム側が守る設計**です。「ユーザーが気をつける」では解決しません。

R1	入力に認証情報が混入する
R2	入力が外部の LLM プロバイダに送られる

秘匿情報の自動マスキング(R1)

保存前・LLM 送信前に自動マスク。**クライアントとサーバの二段構成**で同じ関数を実行します。

- ブラウザ
- ① 貼り付けた瞬間にマスク
- ② 結果をプレビュー表示(送信前に確認)
- ↳ マスク済みテキストのみ送信
- サーバ
- ③ マスキングを再実行(ここが正)
- ↳ データストアへ保存
- ↳ LLM へ送信

プレビューで見た内容と実際に送られる内容がずれません。生のテキストはブラウザから外に出ません。

自動で検出・マスクするもの

API キー類	sk-, ghp_, AKIA 等 → [REDACTED_KEY]
Bearer トークン / JWT	[REDACTED_TOKEN] / [REDACTED_JWT]
接続文字列の資格情報	[REDACTED_CREDENTIALS]
メールアドレス	[REDACTED_EMAIL]
ローカル絶対パス	ファイル名より前をすべて伏せる(中間の顧客名・プロジェクト名も残さない)
登録済みの社名・製品名	[REDACTED_NAME]

正直にお伝えします — 未登録の顧客名などの固有名詞は自動では検出できません。そのため**マスク結果を送信前にプレビューで表示し**、利用者自身が確認・修正できます。何をしていたかを保証していないかを明示する方針です。

LLM プロバイダへの扱い(R2)

学習利用	ゲートウェイ側で学習に使わせない設定を確認・明記
送信内容	マスキング済みテキストのみ。氏名・メールは送らない

API キー・認証・ログ

API キー	ブラウザに出さない。実行環境の環境変数のみ(リポジトリ・CI にも置かない)
登録	招待コード必須 (無制限サインアップを置かない)
パスワード	ソルト付き scrypt でハッシュ化
他人のデータ	キーに所有者 ID を含む構造。他人のセッション ID では「存在しない」しか返らない
ログ	エラー本文・コード断片を残さない 。記録はトークン数・コスト等のメタ情報のみ

濫用への防御

レート制限	セッション作成 10 回/時/ユーザー
トークン上限	1 セッション 80,000 で打ち切り
冪等性	API 直叩きでも LLM を連打させられない
XSS / 通信	LLM 出力を HTML として描画しない / すべて HTTPS

v0.1 で未対応(v0.2 に対応): マルチテナント・監査ログ / SSO / パスワードリセット。やっていないことを「やった」とは書きません。